Arbeidskrav

Governance, risk and Compliance

GRC1100

Akademisk år: 2024/2025

ADVANCED MEDTECH

Where technology meets care

Gruppe: XX

XXXXXXX,
XXXXXX,
Irma Beslic,
XXXXXXXX,
XXXXXXXX

Innholdsfortegnelse

Kapittel 1: Case beskrivelse **3**
Kapittel 2: Kjernevirksomhet, leveranse, prosesser og IKT-støtte **4**
Kapittel 3: Styring **8**
Interne faktorer: 8
Eksterne faktorer: 9
Interessenters behov og forventninger (Krav 4.2): 9
Omfanget av ISMS (Krav 4.3): 10
Etablere ISMS (Krav 4.4): 10
Ledelsens forpliktelse (Krav 5.1): 11
Informasjonssikkerhetspolicy (Krav 5.2): 11
Roller og ansvar (Krav 5.3): 11
Kapittel 4: Etablering av risikostyring **12**
Advanced MedTech's retningslinjer for risikovurdering 12
Risikomatrise 12
Identifisering av risikoer 13
Vurdering 13
Oppfølging 14
Retningslinjer for Informasjonsklassifisering: 14
Beskrivelser 14
Trusselbildet: 15
Kapittel 5: Oversikt kontroll og GDPR **16**
IKT systemportefølje 16
IKT leverandøroversikt 18
Behandlingsprotokollen 18
Kundestøtte og saksbehandling 19
Overvåkning og sikkerhetsprosesser 19
HR og Rekruttering 19
Kapittel 6: Overordnet risikovurdering og digital sikkerhet **20**
Trusler og sårbarheter 20
Verdikartlegging og Informasjonsklassifisering 20
Kritiske digitale verdier for bedriftens funksjon 21
Lagerstyringssystem 21
Hovedrisikoer innenfor digital sikkerhet 22
Statement of Applicability, NSM 15 grunnprinsipper 22
Kapittel 7: Informasjonsklassifisering, angrepsflate og sikkerhetsarkitektur **25**
Informasjonsklassifiseringer, retningslinjer og prosedyrer **25**
Prosedyre for konfidensialitetsklassifisering 27
Angrepsflate og sikkerhetsarkitektur 27
Kapittel 8: Trusselvurdering for bedriften **28**

Trusselaktører og deres motivasjon:....28
Tabelloppsumering:....29
Fem trusler for Advanced Medtech:....29
Kapittel 9: Sårbarhetsvurdering for bedriften....31
Teknologiske sårbarheter....31
Organisatoriske sårbarheter....31
Menneskelige sårbarheter....31
Adressering av sårbarhetene....31
Kapittel 10: Tiltaksanbefaling og beredskapsplan....34
Risikobilde....34
Risikomatrise: Heatmap....36
Business Impact Analysis (BIA)....36
Definer Farer og Ulykkeshendelser (DFU)....36
Tiltak for å håndtere hendelsen:....37
Anbefalte Sikkerhetstiltak:....37
Beredskapsplan:....38
Oppsummering og anbefalinger:....38
Referanseliste:....40

Kapittel 1: Case beskrivelse

Advanced MedTech er et privat aksjeselskap (AS) med hovedkontor i København, Danmark. Bedriften ble grunnlagt for 1,5 år siden med et klart mål om å skape en trygg og pålitelig salgskanal for medisinsk utstyr til nordiske sykehus og klinikker. Med slagordet "Where Technology Meets Care" ønsker vi å tilby høykvalitetsprodukter som møter høye standarder innen medisinsk utstyr, uten selv å utvikle eller designe produktene. I stedet fokuserer vi på å være en pålitelig del av salgskjeden og samarbeider tett med leverandører som Siemens Healthineers, som spesialiserer seg på produktutvikling og innovasjon innen medisinsk teknologi.

Siden Advanced MedTech spesialiserer seg innen salg av medisinsk utstyr, retter vi oss hovedsakelig mot det nordiske markedet innen medisinsk- og helsesektor. Våre primære kunder er offentlige og private sykehus, mens sekundære målgrupper inkluderer andre helseinstitusjoner som klinikker og spesialiserte behandlingssenter. Ved å tilby avanserte medisinske maskiner og teknologi, som for eksempel MR-maskiner og monitoreringsutstyr, bidrar vi til at våre kunder kan behandle pasientene sine på en trygg og effektiv måte.

Vårt unike salgsfortrinn ligger i det sterke fokuset på sikkerhet i systemene vi leverer. Helsebransjen er en av de mest utsatte sektorene når det kommer til sikkerhetsbrudd, og for å forhindre dette har vi etablert en omfattende IT-avdeling. Avdelingen består av konsulenter med spesialisering innen cybersikkerhet som sikrer at alt av utstyr og teknologi som blir implementert hos våre kunder følger strenge sikkerhetsprotokoller. Dette er spesielt viktig når det gjelder håndtering av kundedata og integrasjon av teknologien i sykehusenes eksisterende IT-infrastruktur. Siden helsetjenesten er en sektor med mange dataangrep, sørger vi for at alt utstyr følger regulatoriske krav og opprettholder høy produktkvalitet.

Advanced MedTech har for øyeblikket 35 ansatte, fordelt på tre hovedavdelinger: salg, IT-konsultasjon, og administrasjon. IT-avdelingen utgjør en betydelig del av virksomheten vår, med hovedansvar for å sikre at medisinsk utstyr blir trygt implementert hos våre kunder. Administrasjonsavdelingen støtter den daglige driften og opprettholder våre forretningsprosesser, mens salgsavdelingen har ansvar for å opprettholde og utvide våre kundeforhold. På grunn av vår ekspansjonsstrategi og plan om å etablere kontorer i flere nordiske land, forventer vi en betydelig økning i antall ansatte de kommende årene.

Vår markedsføringsstrategi er basert på B2B-prinsippet ("business-to-business"), hvor vi retter oss mot beslutningstakere på sykehus, som innkjøpsansvarlige og ledere. Dette gjør vi gjennom målrettet bruk av bransjekonferanser, messer og nettverksbygging. I tillegg utnytter vi digitale plattformer som LinkedIn og spesialiserte helsemagasiner for å promotere våre tjenester og ekspertise innen sikkerhet og teknologi. Ved å bygge et sterkt omdømme som en trygg leverandør med høyt fokus på sikkerhet og kvalitet, ønsker vi å posisjonere oss som en ledende aktør innen medisinsk teknologi i Norden.

Økonomisk sett har vi klart å oppnå en årlig inntektsstrøm på omtrent 25 millioner norske kroner etter fradrag av utgifter. Ved oppstart hadde vi en egenkapital på 6 millioner norske kroner og mottok i tillegg 12 millioner norske kroner i ekstern finansiering fra private investorer, noe som ga oss en solid økonomisk plattform å bygge videre på. For å sikre videre vekst, planlegger vi å reinvestere en betydelig del av overskuddet i utvidelse av vår IT-avdeling, som vi ser på som en kritisk faktor for vår suksess i årene fremover.

Post	Beløp (NOK)	Kommentarer
Inntekter	25 000 000 NOK	Årlig inntektsstrøm etter utgifter
Kostnader		
- Salg og markedsføring	3 000 000 NOK	Inkluderer deltakelse på bransjekonferanser og nettverksbygging
- IT-konsultasjon og sikkerhet	7 500 000 NOK	Sikring og implementering hos kunder; inkluderer konsulentkostnader
- Administrasjon og drift	5 500 000 NOK	Dekker lønn, kontorutgifter, og annen drift
- Produktanskaffelse og logistikk	4 500 000 NOK	Kostnader knyttet til leverandører og distribusjon
- Ekspansjon	2 500 000 NOK	Allokering til nyansettelser og etablering i nye markeder
Totale kostnader	23 000 000 NOK	
Overskudd før skatt	2 000 000 NOK	Reinvesteres i IT-avdelingen og ekspansjon

(Fig. 1. Budsjett)

Advanced MedTech er dedikert til å møte de høye kravene innen helse- og teknologiindustrien, og vi fortsetter å utvikle oss som en pålitelig partner for våre kunder, med fokus på sikkerhet, kvalitet og innovasjon i alle ledd av vår virksomhet.

Kapittel 2: Kjernevirksomhet, leveranse, prosesser og IKT-støtte

Vår visjon er å vokse og bli en ledende aktør innen salg av medisinsk utstyr som bidrar til å styrke spesialist- og primærhelsetjenesten i Norden. Hovedmålet er å ivareta konfidensialitet, integritet og tilgjengelighet i alle maskiner og systemer som leveres av oss.
Gjennom bærekraftige løsninger ønsker vi å sette en ny bransjestandard for kvalitet og pålitelighet innen medisinsk utstyr. Videre skal vi sørge for at våre tjenester samsvarer med lover og forskrifter, slik at vi kan opprettholde høye og trygge standarder for kvalitet og sikkerhet.

Kjernevirksomhet og leveranse

Bedriftens hovedaktivitet kan beskrives i tre deler: *Input* (ressurser som trengs), *produksjon* (omforming av råvarer til produkter), og *output* (leveranse til kunder).

Input:

- Kataloger/ Database over medisinsk utstyr og virtuell lagerbeholdning.
- Kontaktinformasjon og samarbeidsavtaler med produktutviklere, fabrikker og leverandører av medisinsk utstyr.
- Kunnskap/ kompetanse om godkjent medisinsk utstyr.
- Arbeidskraft med nødvendig ekspertise.
- Teknologi for effektiv produksjon og distribusjon.
- Samarbeid og partnerskap med relevante aktører.

Produksjon:

- Leveransepresisjon. Sikre at godkjente produkter leveres til avtalt tid og oppfyller alle nødvendige standarder.
- Utgående Logistikk. Sørge for at riktige produkter når til kunden til avtalt tid.

Output:

- Distribusjon av sikkert og godkjent medisinsk utstyr.
- Sertifikater og dokumentasjon som bekrefter at produktene oppfyller kvalitetsstandarder, f.eks. ISO 13485.

Produkter og tjenester som leveres til kunden

Produkter og tjenester Advanced MedTech leverer til kunden er salg og distribusjon av medisinsk utstyr av høy kvalitet, som oppfyller gjeldende lovkrav og standarder, med dokumentasjon som gir kunden tillit til produktets kvalitet og sikkerhet.

Verdiskapning for kundene

Advanced MedTech skaper verdi ved å tilby pålitelige produkter som oppfyller høye kvalitetskrav, samtidig som de sikrer presise leveranser.

Kjerneprosesser

- Ordrebehandling
- Leverandørstyring
- Logistikk og levering
- Samarbeid og partnerskap
- Teknologi

Disse kjerneprosessene sikrer at bedriften kan operere effektivt og tilby produkter av høy kvalitet.

Arbeidsprosesser

Vi har valgt å se nærmere på "Ordrebehandling" av de forskjellige sentrale kjerneprosessene. Ordrebehandlingsprosessen spiller en avgjørende rolle i å oppnå bedriftens målsettinger, spesielt når vi håndterer bestillinger av medisinsk utstyr for sykehus. Siden Advanced MedTech ikke har egen lagerbeholdning og fungerer som et mellomledd mellom sykehusene og produsentene, er det viktig at prosessen er både effektiv og nøyaktig for å støtte overordnede mål.

Her er noen måter ordrebehandlingsprosessen bidrar til bedriftens målsettinger:

Riktige produkter leveres

Ved å nøyaktig behandle og verifisere ordrer, sikrer bedriften at sykehusene mottar det medisinske utstyret de faktisk trenger, noe som bidrar til god kundetilfredshet og et godt omdømme.

Tidsriktige leveranser
Hurtig og feilfri behandling av ordrer minimerer forsinkelser og hjelper sykehusene med å få utstyret de trenger i tide, spesielt i krisesituasjoner der rask tilgang til medisinsk utstyr kan være kritisk.

Sikre nøyaktighet
En robust prosess hjelper bedriften med å følge reguleringer innen medisinsk utstyr og sikre at alt utstyr som leveres, er av riktig kvalitet og sertifisert i henhold til gjeldende standarder.

Ordrebehandlingsprosessen støtter arbeidsprosessene som sikrer at bedriften kan administrere salg, kundeservice og analyse effektivt.

Målsetting:
God virksomhetstyring
Mål: Vi skal fokusere på transparent og ansvarlig styring av selskapet gjennom klare prosesser og prosedyrer som forsikrer at bedriften er i tråd med best praksis og etisk ansvarlighet.
Tiltak: Opprette dedikerte styringskomiteer, for eksempel etiske/compliance - komiteer, for å sikre at virksomheten følger strategier og beslutninger som er i tråd med beste praksis og regulatoriske krav.

Regulatorisk ettergivenhet
Mål: Vi skal sørge for at alle regulatoriske krav som gjelder av medisinsk utstyr, lokalt og internasjonalt, skal følges etter enhver tid. Videre skal vi kontinuerlig overvåke regelverksendringer og tilpasning for å sikre at alle produkter alltid tilfredsstiller gjeldende lovverk.
Tiltak: Virksomheten skal gjennomføre regelmessige internrevisjoner av selskapets prosesser og retningslinjer for å sikre at virksomheten er i samsvar med lovverk og interne policyer. Vi skal også sørge for at eksterne kunder møter internasjonale krav i samsvar med gjeldende lovverk.

Fremme pasientsikkerhet gjennom kvalitetsutstyr
Mål: Vi skal tilby produkter med høyest kvalitet gjennom sertifisering og tester for å sikre høyest mulig pasientsikkerhet.
Tiltak: Virksomheten skal følge til enhver tid sørge for at produktene har alle nødvendige sertifiseringer, nasjonalt og internasjonalt. Samtidig skal vi kun samarbeide med leverandører som oppfyller kvalitet og sikkerhetsstandarder. Videre skal det tilbys systemer for tilbakemelding fra kunder, som vi kan benytte for å overvåke ytelse og sikkerhet rundt produktene våre.

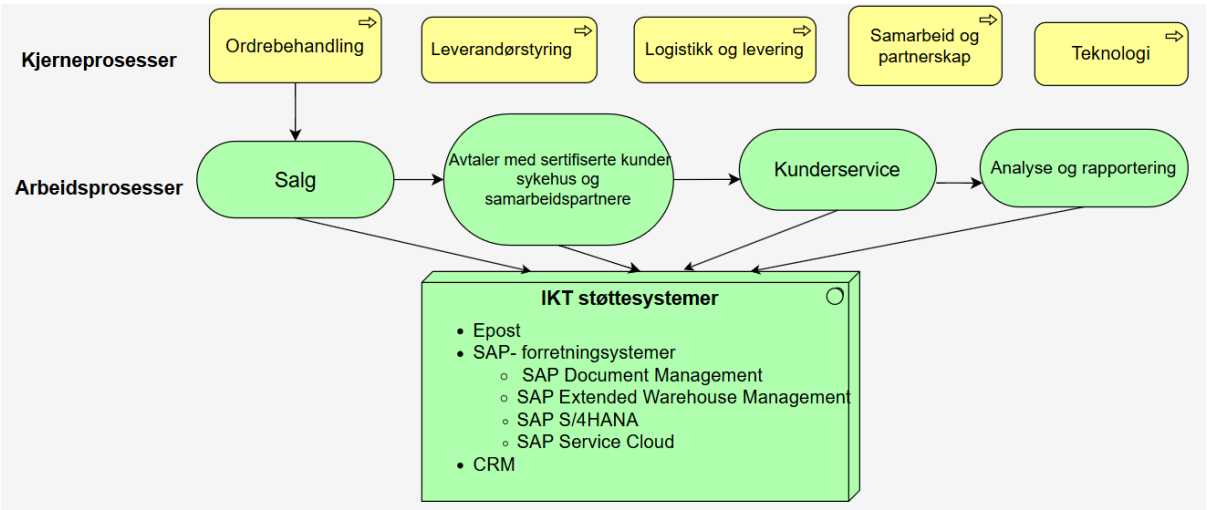
Etiske retningslinjer og bærekraft

Mål: Vi skal følge etiske retningslinjer som sikrer at alle relaterte produkter virksomheten selger, er i samsvar med bransjestandarder for sikkerhet, bærekraft og kvalitet. Videre skal vi sikre bærekraftige innkjøpspraksiser samtidig som vi reduserer miljøpåvirkning.
Tiltak: Utvikle en etisk kode som alle ansatte, leverandører og partnere følger, som inkluderer et system for rapportering av etiske brudd. Videre skal vi minimere avfall i forsyningskjeden ved å bruke resirkulerbare materialer og emballasje, og samarbeide med leverandører som følger miljøvennlige produksjonsprosesser, så langt det lar seg gjøre.

Risikohåndtering
Mål: Redusere risiko gjennom ulike tiltak og etablere beredskapsplan i tilfelle vi blir angrepet.
Tiltak: Identifisere potensielle trusler og sårbarheter i Advanced MedTech og vår drift, og etablere en fullverdig beredskapsplan ved potensielle hendelser samt tilstrekkelig opplæring av ansatte for å sikre at organisasjonen er forberedt på uventede hendelser. Samtidig skal vi holde oss oppdatert på trusselbildet og overvåke risikoscenarier for å tilpasse sikkerhetsstrategien.

Kundefokus og tjenestekvalitet
Mål: Være tilgjengelig 24/7 for rask og effektiv støtte gjennom kundeservice, og kontinuerlig forbedre tjenestene våre gjennom kvalitetssikring.
Tiltak: Opprette kundeserviceavdeling som gir rask og effektiv støtte. Alle produkter skal ha en kvalitetssikring-prosess som oppfyller høye standarder.

IKT-støtte i arbeidsprosessen



(Fig.1. Flytdiagram for IKT støttesystemer)

Advanced MedTech trenger solide arbeidsprosesser og effektiv IT-støtte. Siden selskapet vårt videreselger medisinsk utstyr, er det avgjørende å fokusere på trygge og effektive løsninger i forhold til vår drift. Vårt fokus blir spesielt på å digitalisere salgsprosesser slik at bedriften har høy leveransepresisjon, samsvarer med regulatoriske krav og sikrer god kundeservice.

Siden Advanced MedTech hovedsakelig fokuserer på ordrebehandling, er det kritisk at IKT-prosessene er effektive. Av den grunn har vi implementert en brukervennlig kundeportal. Kundeportalen skal også gi en helhetlig oversikt over tilgjengelige produkter, priser og forventet leveringstid.
Sekundet kunden har lagt inn en bestilling, skal ordren automatisk genereres gjennom systemet, noe som reduserer risikoen for menneskelig feil og effektiviserer prosessen.

Videre skal vi implementere et system som integrerer lagerstatus, betalingsinformasjon, forsendelseprosess og ordregenerering. For å sikre fullstendig kontroll over virksomheten, benytter Advanced MedTech seg av SAP-forretningssystemet som støtter de nødvendige prosessene i virksomheten.

For lagerhåndtering og plukking skal vi benytte et lagerhåndteringssystem for varehusbehandling som oppdateres i sanntid og genererer plukklister for lagerpersonalet som sikrer rask og effektiv varehåndtering. For å sikre nøyaktigheten til ordren skal vi bruke strekkoder og skanning.
For forsending og leveranse av varene skal vi bruke et nøyaktig og effektivt logistikksystem som optimaliserer forsendelseprosessen, som tillater oss å velge den beste leveringsmetoden basert på kundens preferanser. Kunden får også mulighet til å spore ordren i sanntid fra start til slutt.

For optimalt kundestøtte skal vi bruke et CRM-system som håndterer tilbakemeldinger og eventuelle problemer fra kundene. Tjenester som retur, informasjon, ordrestatus og faktura skal CRM-systemet støtte og sikre at kunden får riktig informasjon.

Til slutt skal vi produsere rapporter som gir innsikt i ordrehistorikk, kundepreferanser, leveringstider og lagerbeholdning så virksomheten kontinuerlig forbedres i prosesser og tjenester.

Kapittel 3: Styring

For å jobbe systematisk med sikkerhet og følge beste praksis, må vi i Advanced MedTech forstå vår organisasjon og kontekst, som spesifisert i krav 4.1 i ISO 27001. Dette innebærer å vurdere interne og eksterne faktorer som påvirker vår evne til å levere sikre produkter til helsesektoren.

Interne faktorer:

IT-avdelingens kapasitet og ekspertise: Vår IT-avdeling spiller en sentral rolle i å sikre at medisinsk utstyr vi leverer følger sikkerhetsstandarder. Begrensede ressurser eller manglende

spesialkompetanse kan svekke vår evne til å vedlikeholde sikkerhetstiltak som sårbarhetsanalyser og oppdateringer, noe som øker risikoen for sårbarheter.

Sikkerhetskultur og opplæring blant ansatte: Selv om vi ikke håndterer pasientdata, er det viktig at ansatte er kjent med sikkerhetsprosedyrer, særlig for håndtering av IT-systemer og kundeopplysninger. En sterk sikkerhetskultur reduserer risikoen for sikkerhetsbrudd og styrker vårt forsvar mot eksterne trusler.

Eksterne faktorer:

Regulatoriske krav i helsesektoren: Vi må følge GDPR og nasjonale helseforskrifter som våre kunder (sykehus og klinikker) er underlagt. Dette sikrer at produktene ikke skaper sårbarheter i kundenes IT-systemer og at vi møter sikkerhetskrav som gjelder helsesektoren.

Trusselbildet innen helseteknologi: Helsesektoren er et attraktivt mål for cyberangrep, og medisinsk utstyr kan være sårbart hvis ikke tilstrekkelig sikret. Eksterne trusler, som ransomware og hacking, krever kontinuerlige sikkerhetstiltak for å sikre produkter og beskytte oss og våre kunder.

Disse faktorene viser hvor vi må fokusere sikkerhetsarbeidet, både internt og eksternt. Med en proaktiv tilnærming kan vi styrke vår evne til å levere sikre produkter.

Interessenters behov og forventninger (Krav 4.2):

For å oppfylle kravene til digital sikkerhet, må vi forstå behovene til ulike interessenter:

Kunder: Sykehus og klinikker forventer produkter som er sikre og pålitelige. De prioriterer leverandører som oppfyller strenge kvalitetsstandarder og tilbyr løsninger for effektiv behandling.

Nordiske regulatoriske myndigheter: Vi må følge nasjonale og nordiske reguleringer. Dette er avgjørende for salg av medisinsk utstyr.

Forsikringsselskaper: Disse påvirker utstyrskjøp i helseinstitusjoner og forventer produkter som er effektive og sikre.

Nasjonale krav til digital sikkerhet i Danmark: Danske myndigheter har strenge sikkerhetskrav for helsevesenet. Våre produkter må derfor være pålitelige og motstandsdyktige mot trusler som kan kompromittere både driftsstabilitet og datasikkerhet.

NIS2-direktivet (Network and Information Systems Directive 2):
Dette direktivet krever robust nettverkssikkerhet og informasjonshåndtering i kritisk infrastruktur, inkludert helsevesenet. For oss innebærer det å ha forebyggende tiltak, systemovervåking og rapportering av hendelser (Deloitte, 2023).

GDPR (General Data Protection Regulation):
Selv om vi ikke direkte håndterer pasientdata, påvirkes vi av GDPR gjennom integrasjonen av våre produkter i helsesektorens IT-systemer. Våre løsninger må sikre at sensitive data beskyttes og at ingen uautoriserte aktører får tilgang til informasjon gjennom systemsvakheter (General Data Protection Regulation, 2016, § 2016/679).

ISO 27000-serien:
ISO 27000-standarden krever at vi etablerer et ISMS (Information Security Management System), som følger ISO 27001 (ISO, 2022). Dette innebærer å følge en helhetlig tilnærming til risikoanalyse, kontrollimplementering, samt løpende overvåking og forbedring av sikkerhetstiltak for å beskytte både selskapets systemer og produktene våre.

CIA-triaden
CIA-triaden representerer grunnprinsippene i cybersikkerhet, som våre produkter må oppfylle:

> **Konfidensialitet:** Våre teknologiløsninger skal hindre uautoriserte parter i å få tilgang til sensitiv informasjon (Staff, 2023).
>
> **Integritet:** Produktene må sikre at data behandles og lagres uten uautorisert endring, avgjørende for påliteligheten i medisinsk utstyr (Staff, 2023).
>
> **Tilgjengelighet:** Utstyret må være tilgjengelig til enhver tid og beskyttet mot teknologiske og tjenestenektangrep (Staff, 2023).

Omfanget av ISMS (Krav 4.3):

Vårt ISMS dekker følgende områder:

IT-avdelingen: Har ansvar for dataintegritet og trygg integrasjon av teknologi i sykehussystemer, og det er avgjørende at IT-avdelingen følger sikkerhetsstandarder for å beskytte sensitiv informasjon.

Ledergruppen: Ansvar for strategisk retning og etterlevelse av sikkerhetspolicyer, slik at sikkerhetstiltakene er tilpasset selskapets mål.

Salgsavdelingen: Håndterer kundedata og følger strenge sikkerhetsprotokoller for å sikre konfidensialitet i samhandling med eksterne parter.

Dette omfanget sikrer beskyttelse av viktige funksjoner i vår bedrift.

Etablere ISMS (Krav 4.4):

For å håndtere sikkerhetsrisikoer, vil vi implementere følgende prosesser:

Regelmessige risikovurderinger: IT-avdelingen vil utføre jevnlige risikovurderinger for å identifisere og håndtere trusler, samt evaluere eksisterende sikkerhetstiltak.

Sikkerhetsrevisjoner og oppdateringer: Periodiske revisjoner vil sikre at systemer og programvare følger sikkerhetsstandarder.

Opplæring: Regelmessig opplæring for ansatte i sikkerhetsbevissthet og beste praksis for datahåndtering og passordbruk.

Plan for respons på sikkerhetshendelser (PIR): En plan som sikrer rask respons ved sikkerhetshendelser, for effektiv styring og læring fra tidligere hendelser.

Kontinuerlig overvåking og regelmessige revisjoner vil bidra til å opprettholde effektiviteten i disse prosessene. Ledelsen vil sikre at sikkerhet forblir et fokusområde, og at strategien tilpasses nye trusler.

Ledelsens forpliktelse (Krav 5.1):

Ledelsen støtter vårt sikkerhetsarbeid ved å etablere en sikkerhetskomité ledet av administrerende direktør og sikkerhetsansvarlig. Komiteen prioriterer informasjonssikkerhet og gir retning til sikkerhetsarbeidet.

Informasjonssikkerhetspolicy (Krav 5.2):

Hensikt: Sikre kontinuerlig beskyttelse av informasjon og systemer for å opprettholde omdømme og tillit.

Omfang: Dekker all infrastruktur og sensitiv informasjon.

Sikkerhetsmål:

1. **Beskyttelse av kundedata:** Oppfylle krav om konfidensialitet og unngå GDPR-brudd.
2. **Driftssikkerhet:** Opprettholde kontinuerlig drift for å møte kundenes behov.

Sikkerhetsstrategier: Inkluderer kryptering, brannmurer og opplæring for å styrke sikkerhetskompetansen blant ansatte.

Roller og ansvar (Krav 5.3):

1. **Daglig leder:** Sikrer at sikkerhetstiltakene støtter våre mål og visjoner.
2. **Leder for digital sikkerhet:** Leder sikkerhetsarbeidet og gjennomfører risikovurderinger.
3. **Mellomledere:** Overvåker implementering og rapporterer til ledelsen.
4. **IT-systemeiere:** Vedlikeholder systemer og implementerer sikkerhetsprotokoller.
5. **Alle ansatte:** Følger sikkerhetsprosedyrer og deltar i opplæring for å bidra til en sikkerhetsbevisst organisasjon.

Denne helhetlige ansvarsfordelingen gir Advanced MedTech som bedrift et solid fundament for å opprettholde sikkerhet i hele virksomheten, hvor både ledelsen og de ansatte har en aktiv rolle i å styrke sikkerhetsarbeidet.

Kapittel 4: Etablering av risikostyring

Advanced MedTech's retningslinjer for risikovurdering

Retningslinjene er delt inn i tre faser: Identifisering, vurdering og oppfølging. Formålet med risikovurderingsprosessen er å identifisere, vurdere og håndtere sikkerhetsrisikoer for å beskytte både virksomheten og kundene våre. Som leverandør av medisinsk utstyr til sykehus og helseinstitusjoner, er det avgjørende at vi forhindrer og begrenser enhver risiko som kan påvirke systemets integritet, konfidensialitet og tilgjengelighet.

Risikovurderingen skal følge en strukturert prosess hvor risikoer identifiseres, vurderes og dokumenteres. Først og fremst skal alle avdelinger, men særlig IT-avdelingen, aktivt jobbe med å identifisere mulige sikkerhetsrisikoer. Dette kan inkludere alt fra teknologiske sårbarheter i det medisinske utstyret vi selger, til sårbarheter i våre egne IT-systemer. Alle funn skal dokumenteres i en risikomatrise som kategoriserer risikoene basert på sannsynlighet for at de inntreffer og hvor alvorlig konsekvensene kan være.

Når risikoer identifiseres, vurderer vi dem basert på to faktorer: sannsynlighet og konsekvens. Sannsynligheten viser til hvor sannsynlig det er at en spesifikk risiko vil inntreffe, og denne vurderes som lav, moderat eller høy. Konsekvensen viser til hvor alvorlig påvirkningen vil være dersom risikoen skulle inntreffe. Konsekvensene kan variere fra minimale økonomiske tap til alvorlige brudd på datasikkerhet og tap av tillit blant våre kunder. Konsekvenser klassifiseres som lave, moderate eller kritiske.

Risikomatrise

Sannsynlighet -> Konsekvens	Lav	Moderat	Høy
Lav	Lav	Moderat	Høy
Moderat	Moderat	Moderat	Kritisk
Kritisk	Høy	Kritisk	Kritisk

(Fig. 3. Visuell fremstilling av sannsynlighet vs konsekvens)

Risikoer som anses som kritiske, det vil si med høy sannsynlighet og kritiske konsekvenser, må håndteres umiddelbart ved at passende tiltak implementeres. For risikoer som er lavere på alvorlighetsskalaen, kan vi vurdere risikoaksept, hvor vi velger å akseptere risikoen uten ytterligere tiltak, gitt at den ikke utgjør en betydelig trussel mot virksomheten eller våre kunder.

I tilfellene hvor risikoaksept er akseptabel, vil vi gjennomføre en grundig vurdering basert på risikoens sannsynlighet og konsekvens. Dette er et bevisst valg som kun tas i tilfeller som ikke omhandler personopplysninger og som kan bidra til å balansere kostnad og nødvendighet. Noe som tilsier at Advanced MedTech kun velger denne løsningen i tilfeller med lav risiko og lav konsekvens.

Ansvarsfordelingen er avgjørende for at risikovurderingsprosessen skal fungere effektivt. IT-sikkerhetssjefen har hovedansvaret for å lede prosessen med støtte fra andre ledere i selskapet. Den tekniske staben i IT-avdelingen skal bidra med teknisk innsikt, mens salgsteamet skal gi innspill basert på kundenes sikkerhetsbehov og risikoprofil. IT-avdelingen har også ansvar for å gjennomføre årlige risikovurderinger og vurdere nye trusler som kan dukke opp ved at selskapet ekspanderer og nye kundeforhold etableres.

Herunder kommer en beskrivelse av hver fase:

Identifisering av risikoer

Advanced MedTech identifiserer risikoer gjennom en systematisk tilnærming som inkluderer evaluering av både eksterne og interne faktorer. Når det gjelder eksterne faktorer, samarbeider vi tett med våre leverandører, spesielt Siemens Healthineers, for å sikre at deres standarder for sikkerhet og kvalitet oppfyller våre krav. Ved å gå inn i et samarbeid med Siemens Healthineers kan vi i Advanced MedTech være sikre på at produktene våre oppfyller de spesifikasjonene og sikkerhetsstandardene vi lover våre kunder.

Dermed vurderer vi risiko i henhold til Siemens Healthineers, for å forsikre oss om at de opprettholder høy standard for både sikkerhet og kvalitet. Advanced MedTech vil også utføre en analyse av kundens IT-infrastruktur før implementering av medisinsk utstyr, slik at vi kan identifisere eventuelle svakheter og sårbarheter før integrasjon av utstyret. Videre skal vi ha en fulltallig IT-avdeling for overvåkning av våre systemer. Dette inkluderer oppdateringer og trusler for å motvirke cyberangrep.

Vurdering

Advanced MedTech skal vurdere risiko med persondata i henhold til regulatoriske krav. Dette inkluderer GDPR og andre eventuelle retningslinjer eller rammeverk.
Alle produkter og tjenester tilbudt av Advanced MedTech skal være i samsvar med nasjonale sikkerhets- og IT-standarder innen helsetjenesten. Våre interne systemer skal også gjennomgå regelmessige vurderinger og tester.

Oppfølging

Alle ansatte i Advanced MedTech skal delta på obligatoriske sikkerhetskurs for å regelmessig oppdatere bevissthet angående vår sikkerhetspraksis og risikohåndtering.
Ved eventuelle sikkerhetsrisikoer skal kunden det gjelder kontaktes og informeres om hvilke tiltak som er implementert, slik at de er bevisste over hvordan de er beskyttet mot truslene.

Retningslinjer for Informasjonsklassifisering:

	Konfidensialitet:	**Integritet:**	**Tilgjengelighet:**
Nivå 1	**Offentlig**	**Ingen krav**	**Ingen krav**
Nivå 2	**Intern**	**Forventet**	**2 dager**
Nivå 3	**Fortrolig**	**Avhengig**	**4 timer**
Nivå 4	**Strengt fortrolig**	**Kritisk**	**Umiddelbar**

(Fig. 4. Definisjon av klassifisering basert på CIA-triaden)

Beskrivelser

	Konfidensialitet	**Integritet**	**Tilgjengelighet**
Nivå 1	**Offentlig:** **Informasjonen er offentlig tilgjengelig og har ingen restriksjoner når det kommer til deling.**	**Ingen krav:** **Advanced MedTech har ingen krav til sikring av denne informasjonen.**	**Ingen krav:** **Informasjonen er ikke tidssensitiv og kan være utilgjengelig uten noen konsekvens.**
Nivå 2	**Intern:** **Informasjonen skal kun være tilgjengelig for ansatte og autoriserte personer internt i bedriften, men krever ingen prekær behandling.**	**Forventet:** **Informasjonen bør være pålitelig og korrekt, men små-feil vil ikke ha alvorlige konsekvenser.**	**2 Dager:** **Midlertidig utilgjengelighet kan tolereres, men informasjonen må være tilbake innen to dager.**
Nivå 3	**Fortrolig:** **Informasjonen er sensitiv og kun essensielt autorisert**	**Avhengig:** **Viktig at informasjonen er pålitelig. Feil kan ha**	**4 timer:** **Langvaring utilgjengelighet kan føre til moderate**

	personell skal ha tilgang.	**negative/alvorlige konsekvenser.**	**konsekvenser for Advanced MedTech.**
Nivå 4	**Strengt fortrolig: Informasjonen er kritisk-sensitiv og meget begrenset. Uautorisert tilgang kan føre til alvorlige konsekvenser**	**Kritisk: Informasjonen må være 100% pålitelig. Feil kan ha svært alvorlige konsekvenser.**	**Umiddelbar: Informasjonen må være tilgjengelig umiddelbart. Utilgjengelighet kan føre til alvorlige konsekvenser for både sikkerhet og Advanced MedTech.**

(Fig. 5. Beskrivelser av definisjonene i fig.4)

Trusselbildet:

Det er nevnt tidligere at helsetjenesten er sektoren hvor det blir begått flest datainnbrudd. Dermed vil Advanced MedTech legge ekstra stor vekt på digital sikkerhet, både for våre ansatte og våre kunder. De største sikkerhetstruslene vi står ovenfor, som skal inkluderes i risikovurdering inkluderer, men er ikke begrenset til:

Phishing
Phishing-angrep er en av de mest utbredte metodene for å ta seg inn i systemer og få tilgang til (sensitive) personopplysninger. I helsesektoren kan denne angrepsmetoden resultere i at kundedata blir lekket og/eller kompromittert.

Insider-trusler
Insider-trusler oppstår når ansatte i bedriften vitende eller uvitende utsetter IKT-systemene for risiko. Slike trusler kan påvirke uautoriserte endringer av essensielle systemer, noe som kan ha alvorlige konsekvenser for Advanced MedTech.

Tukling med medisinsk utstyr
For å sikre pasientsikkerhet er medisinskt utstyr avhengig av presis og pålitelig teknologi. Tukling med slikt utstyr kan føre til at maskiner, som for eksempel MR-maskiner ikke fungerer slik som tiltenkt, noe som kan utgjøre en alvorlig trussel for bedriftene som er avhengige av Advanced MedTech's tjenester og produkter.

DDoS angrep

DDoS angrep går ut på at en ondsinnet aktør overbelaster bedriftens systemer med en flod av mye datatrafikk fra ulike kilder og enheter. Et slikt angrep kan i verste tilfelle gjøre det umulig for Advanced MedTech å få tilgang til våre egne data og ressurser. Siden Advanced Medtech har mye data og ressurser knyttet til medisinskt utstyr vil et slikt angrep lede til konsekvenser for både bedrift og kunder, dersom prosessen skulle forstyrres.
Ransomware

Ransomware er en skadelig programvare som angriper bedriftens data og krypterer det og deretter krever løsepenger, dermed også kalt løsepengevirus, slik at bedriften skal betale angriperen for å dekryptere dataene. Den ondsinnede aktøren kan også true med å lekke sensitive data for å legge press på bedriften til å betale løsepengene. Advanced MedTech har en stor omsetning og kan dermed være et sårbart mål for slike angrep.

Advanced MedTech prioriterer identifiseringen av trusler knyttet til digital sikkerhet og forståelsen av at det digitale sikkerhetsbildet utvikles kontinuerlig. Ved å prioritere truslene nevnt ovenfor i vår risikovurdering, vil Advanced MedTech være mer rustet til å beskytte sine systemer, ansatte og kunder mot de mest alvorlige sikkerhetstruslene rettet mot vår bedrift. Ved å følge våre retningslinjer for risikovurdering vil vi ha forbedret våre tiltak for risikoredusering.

Kapittel 5: Oversikt kontroll og GDPR

Her kommer Advanced MedTechs oversikt over de 10 viktigste IT-systemene lagt inn i Diri. Alle systemene, med unntak fra ett, er levert av SAP SE, noe som sikrer enkel integrasjon og sømløs samhandling mellom de forskjellige programmene. Vi bruker også Google Workspace for å støtte samarbeidet og deling av dokumenter på tvers av organisasjonen.

	Navn	Betydning	Operasjonsmodus	Personlige data	Organisasjon	Eier	Leverandør
☐	SAP Analytics Cloud	Veldig	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Magåmed Dålae... ›	SAP SE
☐	SAP HANA Enterprise ... ›	Ekstremt	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Irma Beslic	SAP SE
☐	SAP Service Cloud	Veldig	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Herman Gjeves... ›	SAP SE
☐	SAP SuccessFactors	Veldig	Sky inne i EU	Spesialkategori personopplysninger	Arbeidskrav Gruppe 3... ›	Frida Svendsen ... ›	SAP SE
☐	SAP Document Managem... ›	Veldig	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Mathias Skarås	SAP SE
☐	SAP Enterprise Threa... ›	Ekstremt	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Irma Beslic	SAP SE
☐	SAP Extended Warehou... ›	Veldig	Sky inne i EU	No	Arbeidskrav Gruppe 3... ›	Magåmed Dålae... ›	SAP SE
☐	SAP Customer Experie... ›	Veldig	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Herman Gjeves... ›	SAP SE
☐	SAP S/4HANA	Ekstremt	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Frida Svendsen ... ›	SAP SE
☐	Google Workspace	Ekstremt	Sky inne i EU	Vanlige personopplysninger	Arbeidskrav Gruppe 3... ›	Mathias Skarås	Google

(Fig.1. En oversikt over Advanced MedTech sine 10 viktigste IKT-systemer.)

IKT systemportofølje

Advanced MedTech benytter seg av en rekke integrerte IT-systemer for å støtte forskjellige operasjoner og prosesser innenfor organisasjonen, hovedsakelig fra SAP SE, som sørger for effektivitet.

SAP Analytics Cloud er avgjørende for vår evne til å identifisere innsikter fra store mengder data. Dette systemet, som fungerer hånd i hånd med andre SAP-produkter, sørger for at data flyter jevnt og bidrar til enkel og effektiv rapportering.

Deretter har vi SAP HANA Enterprise, roten i vår datahåndteringsstrategi. Dette kraftige verktøyet er designet for å håndtere alle typer data og bistår vår kapasitet til å ta beslutninger i sanntid - en nødvendighet for vår IT-avdeling.

Når det kommer til kundeservice, er SAP Service Cloud vår ryggrad. Dette systemet fungerer i tett samarbeid med SAP CRM og ERP, og gir oss en komplett oversikt over kundeinteraksjoner og -historikk, noe som gjør at vi kan tilby en serviceopplevelse med god kvalitet.

For vår HR-avdeling er SAP SuccessFactors et godt verktøy. Fra rekruttering til ansattutvikling, hjelper dette systemet oss med å administrere vårt verdifulle menneskelige kapital effektivt, sikret gjennom integrasjon med SAP Service Cloud.

SAP Document Management System sørger for at alle dokumentene er sikre og lett tilgjengelige, grunnet integrasjonen med andre SAP-moduler. Sikkerhet tas videre til et høyere nivå med SAP Enterprise Threat Detection, som beskytter våre data og applikasjoner mot trusler i sanntid.

På logistikkfronten endrer SAP Extended Warehouse Management måten vi håndterer og optimerer vårt lager på, med verdifull støtte fra SAP S/4HANA for å maksimere effektiviteten.

SAP Customer Experience hjelper oss å levere personaliserte kundeopplevelser ved å synkronisere kundeinformasjon på tvers av alle berøringspunkter, styrket av integrasjonen med SAP CRL og Service Cloud.

Og selvfølgelig, SAP S/4HANA, som er selve fundamentet i vårt ERP-system. Det binder alle de andre systemene sammen, slik at vi kan operere effektivt og sømløst.

Selv om det ikke kommer fra SAP, er Google Workspace likevel sentralt i vår daglige drift. Det styrker vår kommunikasjon og samarbeid gjennom verktøy som Gmail, Docs, Drive og Meet, og spiller en viktig rolle i å holde vårt team produktivt og forbundet.

Samlet sett danner disse systemene grunnlaget i vår teknologiske infrastruktur, og sikrer at vi kan møte interne og eksterne utfordringer med tillit og overholde strenge regulatoriske standarder som GDPR.

IKT leverandøroversikt

Våre IT-systemer er drevet av SAP SE og Google, som leverer skalerbare og sikre plattformer for våre behov. SAP SE forsyner oss med integrerte forretningssystemer som forenkler våre prosesser fra logistikk til kundebehandling. Google bidrar med sin infrastruktur, som gir gode muligheter og sikker datalagring. Disse leverandørene er avgjørende for å opprettholde vår forpliktelse til sikkerhet og pålitelighet i leveringen av medisinsk utstyr.

Registrerte leverandører

Se alle leverandører som er registrert i denne organisasjonen. Disse benyttes blant annet i risikovurderinger og databehandl
tabeller lar deg skreddersy kolonnene etter dine behov og redigere direkte i tabellen. Bruk knappen 'Legg til leverandør' øve

Filter

	Navn	Kontaktperson	Telefon	E-post
☐	Google	Kari Nordmann	+47 8987788	kari.n@google.com
☐	SAP SE	Camilla Hjemsæter	+47 99009900	Camilla.h@SAP.no

Figur 2: En oversikt over leverandørene til IKT-systemene Advanced MedTech bruker

Behandlingsprotokollen

Advanced MedTech samler inn og behandler personopplysninger i disse tre prosessene: rekrutteringsprosessen, kundestøtteprosessen, og ansattadministrasjon.

Registrerte Behandlingsaktiviteter

Registrer behandlingsaktivitet

Behandlingsprotokollen dokumenterer hvordan personopplysninger samles inn, behandles, lagres og deles innenfor en organisasjon. Formålet er å sikre transparens, overholde personvernregler og opprettholde dataintegritet og sikkerhet. Administrer dine databehandlingsaktiviteter ved enkelt å legge til nye aktiviteter, redigere eksisterende eller slette utdaterte oppføringer. Bruk alternativet 'Registrer behandlingsaktivitet' for en strømlinjeformet tilnærming til å opprette nye behandlingsaktiviteter.

Filter | Del | Konfigurer

	Navn	Risiko	Tilstand	Status	Formål	Rolle	Juridisk grunnlag	Kategorier av registrerte	Inform
☐	Kundestøtte og saksb...›		Aktiv	● Fullstendig	SAP Service Cloud sa...›	Behandlingsansvarlig	6.1.c 6.1.f	Leverandører Kunder	Start Pre-DPIA
☐	Overvåkning/Sikkerhe...›		Aktiv	● Fullstendig	Å sikre bedrift fra ...›	Behandlingsansvarlig	6.1.a 6.1.b +1	Ansatte Gjester +1	Start Pre-DPIA
☐	HR og Rekruttering		Aktiv	● Fullstendig	Formålet er å ha ove...›	Behandlingsansvarlig	6.1.a 6.1.b	Arbeidstakere Jobbkandid	Start Pre-DPIA

Kundestøtte og saksbehandling

Kundestøtte og saksbehandling i Advanced MedTech innebærer direkte interaksjon med kunder som søker hjelp eller informasjon om våre produkter og tjenester. Her brukes SAP Service Cloud som hovedverktøy for å administrere og dokumentere alle kundehenvendelser, fra innledende kontakt til løsning av saken.

Personopplysninger som samles inn inkluderer kundens navn, kontaktinformasjon, og detaljer relatert til deres forespørsler eller medisinske tilstander der det er relevant. Denne informasjonen brukes til å tilby personlig og effektiv service og support. Sikkerhetsmekanismer som kryptering og tilgangskontroll sikrer at dataene oppbevares sikkert og kun er tilgjengelig for autorisert personell.

Behandlingen av personopplysninger i denne prosessen støtter seg på GDPR artikkel 6.1c og artikkel 6.1f, hvor bedriftens behov for å tilby kundestøtte balanseres mot kundens rettigheter og friheter.

Overvåkning og sikkerhetsprosesser

Advanced MedTechs overvåkning og sikkerhetsprosess fokuserer på å beskytte bedriftens data og IT-infrastruktur mot sikkerhetstrusler og datainnbrudd. Ved hjelp av SAP Enterprise Threat Detection, analyseres dataflyt og aktivitet kontinuerlig for å oppdage og respondere på potensielle sikkerhetshendelser.

Denne prosessen involverer innsamling av loggdata og overvåkningsinformasjon som kan inneholde personopplysninger om ansatte og gjester i virksomhetens lokaler. All data håndteres med strenge sikkerhetstiltak for å forhindre uautorisert tilgang og sikre konfidensialitet.

Behandlingen av personopplysninger i sikkerhetsprosessen er rettferdiggjort under GDPR artikkel 6.1a og 6.1f, hvor de ansattes og gjestenes samtykke til overvåkningen sikres gjennom klare og tydelige kommunikasjonsstrategier.

HR og Rekruttering

HR og rekrutteringsprosessen hos Advanced MedTech håndterer personopplysninger relatert til jobbsøkere og ansatte, fra ansettelsesprosess til daglig HR-forvaltning. SAP SuccessFactors benyttes for å gjennomføre rekruttering, onboarding og personalforvaltning.

Informasjonen samlet inn inkluderer personlig identifikasjon, kontaktdata, profesjonell historikk og i noen tilfeller sensitive data som helseinformasjon. Personverntiltak som kryptering, regelmessige sikkerhetsvurderinger og dataminimering sikrer at personopplysningene håndteres ansvarlig og i henhold til lovverket.

I denne sammenhengen baserer behandlingen av personopplysninger seg på GDPR artikkel 6.1a og artikkel 6.1b og artikkel 9.1a og 9.1b, hvor ansattes og jobbsøkeres personopplysninger behandles på en måte som er nødvendig for ansettelsesforholdets natur og forvaltning.

Kapittel 6: Overordnet risikovurdering og digital sikkerhet

Trusler og sårbarheter

I vår rolle som mellomledd i salg av medisinsk utstyr mellom produsenter og helsetjenester, er bedriften spesielt sårbar for trusler som kan påvirke våre digitale tjenester og systemer. Her er det ikke bare en teknisk gjennomgang av sikkerhetssårbarheter, men en vurdering av de spesifikke truslene som kan ha betydelige konsekvenser for virksomheten.
Det er avgjørende at vi beskytter våre egne systemer, og samtidig har pålitelige og sikre IT-løsninger fra tredjepartsleverandører, som SAP, som ivaretar våre driftssystemer. Den største sårbarheten ligger i de digitale tjenestene som kan bli utsatt for «spoofing» og «DDoS-angrep», samt trusler fra innsiden, som kan innebære lekkasjer av sensitiv informasjon om logistikk og kundeopplysninger, eller misbruk av kredentialer.

De spesifikke sårbarhetene:
Social engineering, utdatert regelverk, utdatert programvare, mangel på sikkerhetsprosedyrer, uregelmessig oppdatering.

Verdikartlegging og Informasjonsklassifisering

	Navn	Type	Konfidensialitet	Integritet	Tilgjengelighet	Risikovurdering	Beskrivelse
☐	Sertifikater og regulatorisk dokumentasjon	Informasjon underlagt annen lovgivning	Open	None	None	Advanced MedTech	Dokumentasjon som bekrefter at medisinsk utstyr overholder nødvendige kvalitetsstandarder.
☐	Leverandør og samarbeidsavtaler	Annet	Confidential	Dependent	2 Days	Advanced MedTech	Informasjon om avtaler, kontrakter og priser med leverandører og strategiske partnere.
☐	Lagerstyringssystem	Annet	Strictly Confidential	Dependent	2 Days	Advanced MedTech	Data om lagerbeholdning
☐	Kundedatabase	Brukernavn og passord	Open	Dependent	2 Days	Advanced MedTech	Inneholder informasjon om kundene, deres bestillinger, personlige opplysninger, kjøpshistorikk.
☐	IT-systemer/ Drift o...	Infrastruktur og maskinvare	Internal	Dependent	Immediate	Advanced MedTech	Digitale systemer som styrer bedriftens operasjoner og tredjepart leverandører av interne ressurs system
☐	Finansielle data	Finansielle data	Strictly Confidential	Critical	2 Days	Advanced MedTech	Inneholder detaljert informasjon om bedriftens økonomi, inkludert regnskapsdata, inn- og utbetalinger, sa
☐	Statlige Aktører	Infrastruktur og maskinvare	Confidential	Critical	4 Hours	Statlige Aktører	Deres intensjon kan være å skaffe seg tilgang til store mengder data uten å bli oppdaget. Dette inkluderer

(Fig.6. Denne tabellen viser vurdering av verdiene i bedriften og informasjonsklassifisering med verktøyet Diri.)

Kritiske digitale verdier for bedriftens funksjon

Lagerstyringssystem

Konfidensialitet (Strengt fortrolig)

Lagerstyringssystemet inneholder detaljert informasjon om tilgjengelige produkter, innkommende og utgående varer, og produktenes plassering. Denne informasjonen er strengt fortrolig fordi uautorisert tilgang kan gi konkurrenter eller andre uvedkommende innsikt i lagersituasjonen, noe som potensielt kan utnyttes kommersielt eller forårsake faktureringssvindel.

Sertifikater og Regulatorisk Dokumentasjon
Integritet (Kritisk)
Sertifikater og regulatorisk dokumentasjon sikrer at produktene overholder nødvendige kvalitets- og sikkerhetsstandarder. Det er avgjørende at integriteten til denne dokumentasjonen opprettholdes, da feil eller manipulasjon kan føre til at medisinsk utstyr blir avvist av tilsynsmyndigheter. Dette kan resultere i alvorlige økonomiske tap og tap av kundetillit, samt risiko for at kritiske leveranser til sykehus blir forsinket eller stoppet.

Tilgjengelighet (Umiddelbar)
Tilgjengeligheten til sertifikater og regulatorisk dokumentasjon må være umiddelbar. Hvis disse dokumentene ikke er tilgjengelige ved kontroll eller inspeksjon, kan bedriften risikere alvorlige forsinkelser, og dette får direkte konsekvenser for pasientbehandlingen på sykehusene.

Finansielle Data
Konfidensialitet (Strengt fortrolig)
Finansielle data inneholder sensitiv informasjon om bedriftens økonomi, inkludert fakturaer, regnskap og lønnssystemer. Denne informasjonen er strengt fortrolig fordi uautorisert tilgang kan føre til økonomisk svindel eller lekkasje av sensitiv lønnsinformasjon, noe som kan påvirke både ansatte og bedriftens omdømme.

Integritet (Kritisk)
Integriteten til finansielle data er kritisk for å sikre korrekt regnskapsføring og rapportering. Eventuelle feil eller manipulasjoner kan føre til store økonomiske tap, fakturasvindel, feilaktige avgiftsrapporteringer og potensielle juridiske problemer. Nøyaktige finansielle data er også viktige for bedriftens beslutningstaking og for å opprettholde tillit hos samarbeidspartnere.

IT-systemer / Drift og Infrastruktur
Tilgjengelighet (Umiddelbar)
Bedriftens IT-infrastruktur og driftskritiske systemer som ERP (Enterprise Resource

Planning), CRM (Customer Relationship Management) og SCM (Supply Chain Management) er fundamentale for virksomhetens daglige operasjoner. Disse systemene må være umiddelbart tilgjengelige for å sikre at kommunikasjon, logistikk, lagerstyring og kundebehandling kan skje uten avbrudd. Enhver nedetid i disse systemene kan føre til store operasjonelle problemer, forsinkelser i leveranser og økonomisk tap.

Disse digitale verdiene representerer noen av de mest sårbare punktene i bedriftens drift. Ved å sikre konfidensialitet, integritet og tilgjengelighet i lagerstyringssystemet, sertifikater, finansielle data og IT-infrastruktur, reduserer bedriften risikoen for driftstans, store økonomiske tap, og tap av tillit.

Hovedrisikoer innenfor digital sikkerhet

I risikovurderingen har vi valgt å fokusere på to kritiske digitale risikoer som uautorisert tilgang via brukernavn og passord, og risikoen for single point of failure (SPOF). Vi har valgt å kun skrive om disse to i rapporten for å begrense lengden, men vi har lagt inn 9 risikoer i Diri med tilhørende sårbarheter.

Brukernavn og passord utgjør en av de mest grunnleggende, men også sårbare formene for autentisering. Hvis en angriper får tilgang til påloggingsinformasjon, kan de potensielt få autorisert tilgang til sensitive systemer som CRM, ERP. Dette innebærer risikoen for "privilege escalation," der en uautorisert bruker kan oppnå høyere tilgangsnivå enn de opprinnelig har og dermed få tilgang til sensitive data eller administrative funksjoner. Dette kan føre til datalekkasjer som eksponerer konfidensiell informasjon om kunder og leverandører, eller gir angriperen mulighet til å manipulere kritiske prosesser, for eksempel endring i lagerbeholdning eller ordrebehandling. Slike angrep kan ha betydelige økonomiske tap, spesielt innen helsesektoren, der personvern og informasjonssikkerhet er forankret i lovverket.

Single point of failure (SPOF) refererer til en situasjon der ett enkelt system eller en komponent i infrastrukturen er så kritisk at en svikt i denne komponenten kan lamme hele driften. For bedriften kan dette inkludere kjernesystemer som ERP (Enterprise Resource Planning), som håndterer lagerstyring og ordreadministrasjon, eller SCM (Supply Chain Management), som er avgjørende for logistikken. Hvis disse systemene går ned, kan bedriften miste evnen til å behandle ordrer, koordinere leveranser, eller holde oversikt over lagerbeholdningen.

I tillegg vil en SPOF i driftskritiske systemer også kunne påvirke tilkoblede systemer og prosesser, noe som kan føre til forsinkelser i leveranser og økonomiske tap. Dette er spesielt alvorlig i helsesektoren, der forsinkelser kan ha konsekvenser for pasientbehandlingen.

Statement of Applicability, NSM 15 grunnprinsipper

Advanced MedTech sin Statement of Applicability (SoA) er basert på 15 grunnprinsipper fremlagt av nasjonal sikkerhetsmyndighet(NSM). Disse presenterer oss med en

grunnleggende fremgangsmåte angående vår tilnærming til sikring av systemer. Prinsippene dekker et stort spekter av sikkerhetskrav ved å inkludere tiltak fra alle kategorier: identifisere og kartlegge, beskytte og opprettholde, oppdage, samt håndtere og gjenopprette.

Control Ref	Control	Control Description	Applied (JA/Nei)	Reason(s) for Selection	Associated Assets
1.2.3	Kartlegg enheter i bruk i virksomheten	Alle enheter i virksomheten må kartlegges for å ha oversikt over IT-infrastruktur.	Ja	Risikoanalyse	Alle enheter
1.2.4	Kartlegg programvare i bruk i virksomheten	Kartlegging av all programvare for å sikre kontroll over systemer som kjøres.	JA	Risikoanalyse	Applikasjoner, systemer
2.1.2	Kjøp moderne og oppdatert maskin- og programvare	Sørge for at maskinvare og programvare er oppdatert for å redusere sårbarheter.	Ja	Sikkerhet og effektivitet	Maskinvare, programvare
2.1.9	Ta ansvar for virksomhetens sikkerhet ved tjenesteutsetting	Sikre at eksterne leverandører overholder sikkerhetskrav.	JA	Risikoanalyse	Eksterne tjenester, data
2.2.3	Del opp virksomhetens nettverk etter risikoprofil	Nettverkssegmentering basert på risiko for å begrense skader ved sikkerhetsbrudd.	Ja	Risikoanalyse	Nettverk, datastrømmer
2.3.1	Etabler et sentralt styrt regime for sikkerhetsoppdater ing	Sentraliserte rutiner for oppdatering av systemer og applikasjoner.	Ja	Reduksjon av sårbarheter	Systemer, applikasjoner
2.3.2	Konfigurer klienter slik at kun kjent programvare kjører	Kun godkjente applikasjoner skal kjøres på klienter for å redusere risiko.	Ja	Kontroll på applikasjoner	Klienter, programvare

2.3.3	Deaktiver unødvendig funksjonalitet	Fjerne overflødige funksjoner for å minimere angrepsflater.	Ja	Sikkerhet	Systemer, enheter
2.3.7	Endre alle standardpassord på IKT-produkter før produksjonssetting	Standardpassord må endres før implementering for å sikre mot innbrudd.	JA	Forebygging av uautorisert tilgang	Alle IKT-produkter
2.6.4	Minimer rettigheter til sluttbrukere og spesialbrukere	Begrensede rettigheter til det som er nødvendig for å utføre arbeidsoppgaver.	JA	Prinsippet om minste privilegium	Brukerkontoer, tilgangsnivåer
2.6.5	Minimer rettigheter på drifts-kontoer	Reduksjon av administrative rettigheter for å hindre misbruk.	JA	Reduksjon av risiko	Driftskontoer, administrasjon
2.9.1	Legg en plan for regelmessig sikkerhetskopiering	Etablere en strategi for backup av virksomhetsdata.	JA	Forhindring av tap av data	Data, backup-systemer
3.2.3	Avgjør hvilke deler av IKT-systemet som skal overvåkes	Definere kritiske systemer som krever overvåking for å identifisere sikkerhetshendelser.	JA	Risikoanalyse	IKT-systemer, nettverk
3.2.4	Beslutt hvilke data som er sikkerhetsrelevant	Identifisere sikkerhetskritiske data som skal samles inn og overvåkes.	JA	Risikoanalyse	Data, logger, hendelser
4.1.1	Etabler et planverk for hendelseshåndtering	Utvikle prosedyrer for å håndtere sikkerhetshendelser effektivt.	JA	Hendelseshåndtering	Data, systemer, prosesser

(Fig. 7. Tabell av NSM sine 15 grunnsikringsprinsipper)

Kapittel 7: Informasjonsklassifisering, angrepsflate og sikkerhetsarkitektur

Informasjonsklassifiseringer, retningslinjer og prosedyrer

Ledergruppen og IT-avdelingen hos Advanced MedTech har konkludert med at systemer klassifisert som kritisk, strengt fortrolig og umiddelbar krever at ekstra tiltak implementeres. Vi forvalter informasjonsverdier som: Kundedata, ansattopplysninger, leverandør- og samarbeidsavtaler, finansielle data, sertifikater og regulatorisk dokumentasjon, IT-system- og infrastrukturdata.

når konfidensialiteten er klassifisert som strengt fortrolig er det viktig for Advanced MedTech å implementere tiltak og krav for å beskytte mot uautorisert tilgang, slik at sensitiv informasjon forblir privat. De viktigste kravene som bør være på plass angående tilfeller med slik klassifisering er:

Tilgangskontroller og adgangskontroller
Vi i Advanced MedTech opererer med prinsippet om minste privilegium, som går ut på at kun autorisert personell skal ha tilgang til informasjon basert på deres arbeidsoppgaver.
Vi bruker også multifaktorautentisering, noe som beskytter innloggingen på systemene våre. I tillegg til dette bruker vi også rollebasert tilgang(RBAC). Dette har vi implementert for å ha kontroll på hvilke ansatte som kan se, lese eller redigere informasjon. Noe som sikrer at sensitive data kun kan bli redigert av autentisert personell med redigeringstilgang.

Vi fokuserer også på fysisk sikkerhet ved å integrere adgangskontroll i form av adgangskort med 4-sifret kode. Dette har blitt gjort for å ha kontroll over hvilke ansatte som har tilgang til hvilke ressurser, som igjen bygger på det minste privilegiumsprinsippet.

Kryptering
Ende-til-ende kryptering benyttes når data skal sendes til for eksempel en ekstern samarbeidspartner, slik at kun mottaker kan dekryptere informasjonen. Internt bruker vi TLS protokoller, for å motvirke avlytting. Vi benytter oss også av kryptering når informasjon lagres på våre servere. Dette gjøres for å beskytte informasjonen fra uautorisert tilgang.

Logging og overvåking
IT-avdelingen har hovedansvaret for analyse av logger, samt sanntidsovervåkning av systemene våre for å oppdage uautorisert aktivitet eller potensielle sikkerhetsbrudd. De jobber også regelmessig revisjon av loggene, slik at vi er sikre på at det ikke har forekommet noen former for uautorisert aktivitet eller tilgang.

Backup
Advanced Medtech tar sikkerhetskopier, som blir kryptert før lagring på våre servere. Dermed sikrer vi tilgang på data, dersom et angrep eller datatap forekommer.

Opplæring og bevisstgjøring
Som nevnt tidligere holder Advanced Medtech obligatoriske sikkerhetskurs for alle ansatte, i håp om å skape en god sikkerhetskultur på arbeidsplassen. Ansatte med særskilte tilganger til for eksempel sensitiv informasjon må gjennomgå spesialiserte kurs på hvordan slik informasjon skal håndteres. I tillegg til dette tilrettelegger vi for at alle ansatte skal være opplyste når det kommer til bruk av sikre verktøy og beredskap.

Jevnlige risikoanalyser og testing
IT-avdelingen sørger for at bedriften gjennomfører jevnlig testing av systemer for å luke ut eventuelle sårbarheter. De gjennomfører også risikoanalyser for å oppdatere oss på trusselbildet, noe som fører til at vi kan justere tiltakene i henhold til et endrende trussellandskap.

Flere av kravene nevnt ovenfor, som tilgangskontroll, logging og overvåking, samt opplæring og bevisstgjøring er også relevante i tilfeller hvor informasjonens integritet er klassifisert som kritisk, men vi i Advanced MedTech vil implementere et eget krav i henhold til høyeste grad av integritetsklassifisering.

SAP Enterprise Threat Detection(ETD)
Advanced MedTechs IT-avdeling har et threat detection-system som bistår med å oppdage datamanipulasjon i tillegg til logging og overvåkning. Dette har blitt integrert da IT-avdelingen ikke har kapasitet til å overvåke systemene våre i alle døgnets timer.

Flere av kravene nevnt ovenfor er også relevante i tilfeller med høyeste klassifiseringsgrad av tilgjengelighet, som er umiddelbar. Disse kravene inkluderer logging og overvåking hvor IT-avdelingen gjennomfører sanntidsovervåking, samt backup som innebærer at vi har sikkerhetskopier å referere til, dersom informasjonsintegriteten blir angrepet. I tillegg til dette har vi valgt å implementere et ekstra krav som er spesielt rettet mot informasjonens integritet.

Digitale signaturer og sjekksummer
Ved å integrere digitale signaturer og sjekksummer ved hjelp av SHA- og AES hash-algoritmene som standard, sikrer Advanced MedTech mot uautoriserte endringer ved hjelp av “forsvar i dybden"-metoden. Digitale signaturer sørger for at informasjon kommer fra en pålitelig kilde og at den ikke har blitt endret på under transitt eller lagring. Sjekksummer er et effektivt tiltak som hjelper oss med å bekrefte at informasjonen ikke unnviker fra original tilstand.

Prosedyre for konfidensialitetsklassifisering

Konfidensialitet	Offentlig	Intern	Fortrolig	Strengt fortrolig
Håndtering	Offentlig informasjon har grunnleggende beskyttelse og kan både lagres og deles uten spesifikke avgrensninger.	Intern informasjon lagres i interne systemer og deles kun til nødvendig personell	Fortrolig informasjon skal lagres i systemer med RBAC protokollen implementert i tillegg til multifaktorautentisering	Strengt fortrolig informasjon skal lagres i sikre og krypterte systemer. Her er multifaktorautentisering pålagt
Tiltak	Backup	multifaktorautentisering, backup	Tilgangskontroll, logging og overvåking, backup	Kryptering, tilgangskontroll, logging og overvåking, backup, ETD

(Fig. 8, håndtering og tiltak ved konfidensialitetsklassifisering. Ref fig.5 Beskrivelser)

Advanced MedTech følger denne prosedyren for å sikre at alle ansatte er bevisste på hvilke tiltak som gjelder for de forskjellige typene konfidensialitetsklassifisering. Prosedyren sørger også for at informasjonen håndteres korrekt, noe som ivaretar konfidensialiteten basert på klassifiseringen når alle tiltakene

Angrepsflate og sikkerhetsarkitektur

Advanced MedTech tar hensyn til trusselbildet og reflekterer over angrepsflaten i den formen av å opprettholde kritiske systemer. Da vi fungerer som et mellomledd mellom produsenter og sykehus er det viktig at vi prioriterer IT-infrastrukturen. Alle våre servere, enheter, systemer og databaser kan være eventuelle inngangspunkter for cyberkriminalitet. Selve integreringen av utstyret vårt på sykehusene sine systemer kan føre til risiko for hacking. Advanced MedTechs samarbeid med Siemens Healthineers kan også bli en inngangsport for cyberkriminalitet dersom de har sårbarheter i sine systemer. Vi er også avhengig av SAP som leverandør av våre tjenester. Dersom de skulle blitt utsatt for et angrep vil vi og våre kunder bli direkte berørt av for eksempel nedetid.

Sikkerhetsarkitekturen til Advanced MedTech må leve opp til en satt standard slik at alle truslene presentert av angrepsflaten dekkes. Derfor har vi implementert tiltakene nevnt

ovenfor: Tilgangskontroller og adgangskontroller, kryptering, logging og overvåking, backup, opplæring og bevisstgjøring, jevnlige risikoanalyser og testing, ETD-løsning, samt digitale signaturer og sjekksummer. Med disse tiltakene implementert har vi en sterk sikkerhetsarkitektur. Noe som vil både hjelpe og beskytte oss mot eventuelle angrep. Disse tiltakene er også integrert for å opprettholde konfidensialitet, integritet og tilgjengelighet. Ved å kontinuerlig overvåke systemene vi har i bruk, vil det være enklere for IT-avdelingen å identifisere eventuelle forbedringer i håp om å minske angrepsflaten.

Kapittel 8: Trusselvurdering for bedriften

Advanced MedTechs kjernevirksomhet i helsesektoren gjør oss til et attraktivt mål for flere typer trusselaktører. Statlige aktører og private selskaper kan ha interesse av å få tilgang til helseinformasjon og annen sensitiv informasjon, både for økonomiske og strategiske fordeler. Slike data har høy verdi og kan brukes til forskning, teknologisk utvikling eller på det svarte markedet. Eksempler fra helsesektoren, som angrepet på Helse Sør-Øst i 2018 der pasientdata ble kompromittert (Kolseth, 2018), viser hvor alvorlige slike angrep kan være, selv når enkle hackingmetoder benyttes.

Trusselaktører og deres motivasjon:

1. **Statlige aktører (nasjonalstatlig spionasje):** Motiveres av nasjonal sikkerhet, teknologisk overlegenhet og økonomisk konkurransefortrinn. Disse aktørene søker ofte sensitive helsedata som kan brukes i forskning og utvikling.
    - **Potensielle hendelser:** Spionasje, datatyveri, langvarig systemtilgang for informasjonsinnhenting.
2. **Konkurrenter:** Ønsker å oppnå økonomisk vinning og markedsfordeler ved å skaffe forretningshemmeligheter, prisstrategier og forskningsdata.
    - **Potensielle hendelser:** Datatyveri, økonomisk spionasje, manipulasjon av forretningskritiske systemer.
3. **Hacktivister:** Drives av ideologiske eller politiske motiver og kan angripe selskaper som de mener bryter med deres verdier. De søker ofte å svekke selskapets omdømme eller påvirke praksis.
    - **Potensielle hendelser:** Tjenestenektangrep (DDoS), lekkasje av sensitiv informasjon, systemskade.
4. **Kriminelle organisasjoner (cyberkriminalitet):** Ønsker økonomisk gevinst gjennom utpressing, datatyveri eller annen kriminell aktivitet.
    - **Potensielle hendelser:** Ransomware-angrep, tyveri av data for videresalg, økonomisk utpressing.
5. **Insidere (interne ansatte):** Motiveres av personlig vinning, misnøye eller press fra eksterne aktører.
    - **Potensielle hendelser:** Sabotasje, tyveri og lekkasje av sensitive opplysninger.

Tabelloppsumering:

Trusselaktører	Motivasjon	Intensjon	Potensielle hendelser
Statlige aktører	Nasjonal sikkerhet, teknologi	Skjult langvarig tilgang til sensitiv data	Spionasje, datatyver
Konkurrenter	Økonomisk vinning	Stjele forretningshemmeligheter	Økonomisk spionasje, datatyveri
Hacktivister	Ideologiske eller politiske	Svekke omdømme eller tvinge endringer	Tjenestenektangrep, lekkasje av data
Kriminelle organisasjoner	Økonomisk vinning	Utpressing eller salg av data	Ransomware, data tyveri
Insider	Personlig vinning eller tvang	Misbruk av tilgang eller sabotasje	Sabotasje, tyveri av informasjon

(Fig. 9. Tabelloppsummering av trusselaktører)

Fem trusler for Advanced Medtech:

(Rangering 1 = Mest alvorlig, 5 = Minst alvorlig)

1. **Ransomware-angrep**
- Kapasitet: Høy – Kan lamme bedriftens operasjoner, blokkere tilgang til kritiske systemer og forårsake store økonomiske tap.
- Kapabilitet: Moderat til høy – Distribueres ofte gjennom phishing-e-poster eller sårbare systemer.
- Hyppighet: Høy – Særlig vanlig mot helsevesenet grunnet høy verdi på sensitiv data.
- Alvorlighet: 1

2. **Datatyveri og spionasje**
- Kapasitet: Høy – Tyveri av pasientinformasjon kan gi juridiske, økonomiske og omdømmemessige konsekvenser.
- Kapabilitet: Høy – Statlige og avanserte aktører kan gjennomføre sofistikerte spionasjeangrep.
- Hyppighet: Moderat – Helsebransjen er et attraktivt mål for både økonomisk spionasje og statlig etterretning.
- Alvorlighet: 2

3. **Insidertrusler**

- Kapasitet: Moderat til høy – Insidere kan forårsake alvorlig skade ved lekkasje eller sabotasje.
- Kapabilitet: Moderat – Krever ikke høy teknisk kompetanse på grunn av eksisterende tilgang til systemene.
- Hyppighet: Moderat – Selv om sjeldnere, er konsekvensene betydelige.
- Alvorlighet: 3

4. Tjenestenektangrep (DDoS)

- Kapasitet: Moderat – Kan forstyrre drift og svekke omdømme, men fører sjelden til varig skade.
- Kapabilitet: Lav til moderat – Kan utføres av både hacktivister og kriminelle med minimale ressurser.
- Hyppighet: Høy – Hyppig brukt for å svekke omdømme eller legge press.
- Alvorlighet: 4

5. Phishing-angrep

- Kapasitet: Moderat – Kan gi angripere tilgang til sensitiv informasjon eller installere ondsinnet programvare.
- Kapabilitet: Lav – Enkelt å gjennomføre, men svært effektivt, spesielt uten tilstrekkelig opplæring blant ansatte.
- Hyppighet: Høy – Svært vanlige, med høy suksessrate.
- Alvorlighet: 5

Tabelloppsumering:

Trussel	**Kapasitet**	**Kapabilitet**	**Hyppighet**	**Alvorlighet (Rangering)**
Ransomwareangrep	Høy	Moderat til høy	Høy	1
Datatyveri	Høy	Høy	Moderat	2
Insider trusler	Moderat til høy	Moderat	Moderat	3
Tjenestenektangrep (DDoS)	Moderat	Lav til moderat	Høy	4
Phishing-angrep	Moderat	Lav	Høy	5

(Fig.10. Tabelloppsummering av relevante trusler)

Kapittel 9: Sårbarhetsvurdering for bedriften

For å styrke vårt forsvar mot en rekke sikkerhetstrusler, har Advanced MedTech identifisert og kategorisert nøkkelområder av sårbarheter innenfor vår drift. Disse sårbarhetene er gruppert i tre kategorier: Teknologiske sårbarheter, organisatoriske sårbarheter, og menneskelige sårbarheter. Denne tilnærmingen gjør det mulig for oss å tildele ressurser mer effektivt og implementere målrettede sikkerhetstiltak som adresserer spesifikke risikoer.

Teknologiske sårbarheter

Dette inkluderer sårbarheter som er direkte relatert til teknologien og systemene vi bruker. Her har vi identifisert utdatert programvare, som er en risiko forbundet med å bruke programvare som ikke lenger støttes eller som mangler de nyeste sikkerhetsoppdateringene. Vi identifiserte også sårbarheten uregelmessig oppdatering, dette kan oppstå når systemer og programvare ikke regelmessig oppdateres med de nyeste sikkerhetsforbedringene.

Organisatoriske sårbarheter

Sårbarhetene i denne kategorien er knyttet til måten vi er strukturert og opererer på. Dette inkluderer utdatert regelverk, mangel på prosedyrer og underbemanning. Utdatert regelverk kan oppstå når prosedyrer ikke holder tritt med nåværende beste praksiser, teknologiske fremskritt eller regulatoriske krav. Vi identifiserte deretter mangel på prosedyrer som er direkte mangel på hvordan spesifikke sikkerhetsrelaterte aktiviteter håndteres eller dokumenteres. Så til slutt har vi underbemanning, som er når det ikke er nok personell til å dekke sikkerhetsbehovene, noe som kan føre til tilsynelatende eller faktiske sikkerhetsbrudd.

Menneskelige sårbarheter

Sårbarhetene her stammer fra menneskelig adferd og interaksjon. Her identifiserte vi én sårbarhet, social engineering. Dette er manipulasjonsteknikker som brukes for å lure folk til å gi fra seg sensitiv informasjon eller til å utføre handlinger som kompromitterer sikkerheten.

Adressering av sårbarhetene

Årsaksnavn *
Stjålet sensitiv opplysning

Beskrivelse
Risiko for sensitiv informasjon blir lekket gjennom uautorisert tilgang, datainnbrudd eller svikt i sikkerhetstiltak.
Dette kan føre til informasjon som personlig opplysninger blir hentet ut, finansiell data og helseopplysninger

Sårbarhet
Social engineering

Trusselaktør
Hacktivister X Statlig aktør X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Manglende samsvar med regulatoriske krav

Beskrivelse
Hvis virksomheten bryter GDPR regelverket, kan det medføre til sanksjoner og bøter.

Sårbarhet
Utdatert regelverk

Trusselaktør
Insider X Velg et alternativ

Low Middle High Critical

Arsaksnavn *
Feil med produkter

Beskrivelse
Svikt i kommunikasjon med leverandører eller mangel på prosedyrer kan føre til feil av utstyr

Sårbarhet
Utdatert programvare

Trusselaktør
Intern X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Manglende sikkerhetsbesvissthet

Beskrivelse
Ved dårlig sikkerhetsopplæring kan menneskelig feil føre til for eksempel phishing angrep

Sårbarhet
Mangel på prosedyrer

Trusselaktør
Insider X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Utilstrekkelig back-up

Beskrivelse
Back-up er kritisk for virksomheten sine systemer og ved påførende mangel på dette vil infrastrukturen gå ned

Sårbarhet
Velg en sårbarhet

Trusselaktør
Intern X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Dårlig lagerstyring

Beskrivelse
Dårlig prosesser rundt lagerstyring kan føre til forsinkelser

Sårbarhet
Mangel på prosedyrer

Trusselaktør
Intern X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Delvis utdatert utstyr/programvare

Beskrivelse
Ved manglende oppdateringen på programvare eller eldre teknologi, kan det påføre sikkerhetsrelatert problemer eller ekstra kostnader for bedriften

Sårbarhet
Utdatert programvare

Trusselaktør
Konkurrenter X Velg et alternativ

Low Middle High Critical

Årsaksnavn *
Overbelastning for kundeservice

Beskrivelse
Ved for høy belastning av kundeservice, kan det medføre lengre ventetid til kunder

Sårbarhet
Underbemanning

Trusselaktør
Intern X Velg et alternativ

Low Middle High Critical

Årsaksnavn *

Mangelfull oppdatering på materiale

Beskrivelse

Ved dårlig oppdatering av informasjon til produktene kan det redusere innkjøp av varer

Sårbarhet

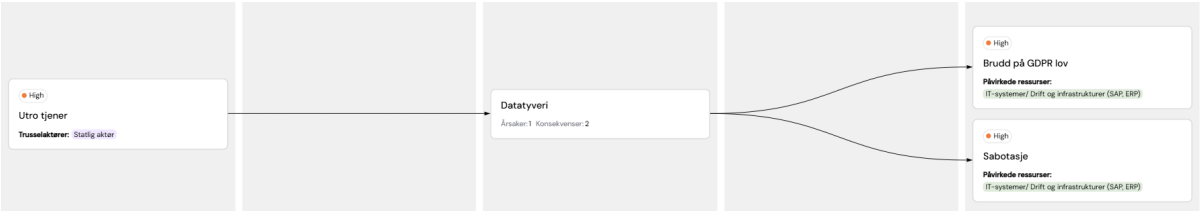
Uregelmessig oppdatering

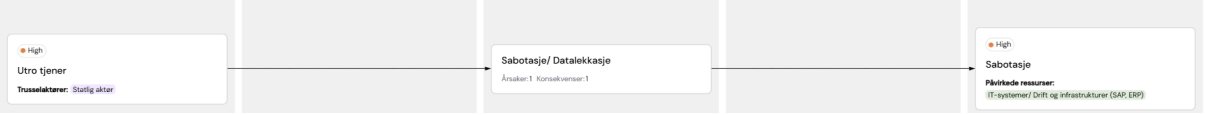
Trusselaktør

Intern X Velg et alternativ

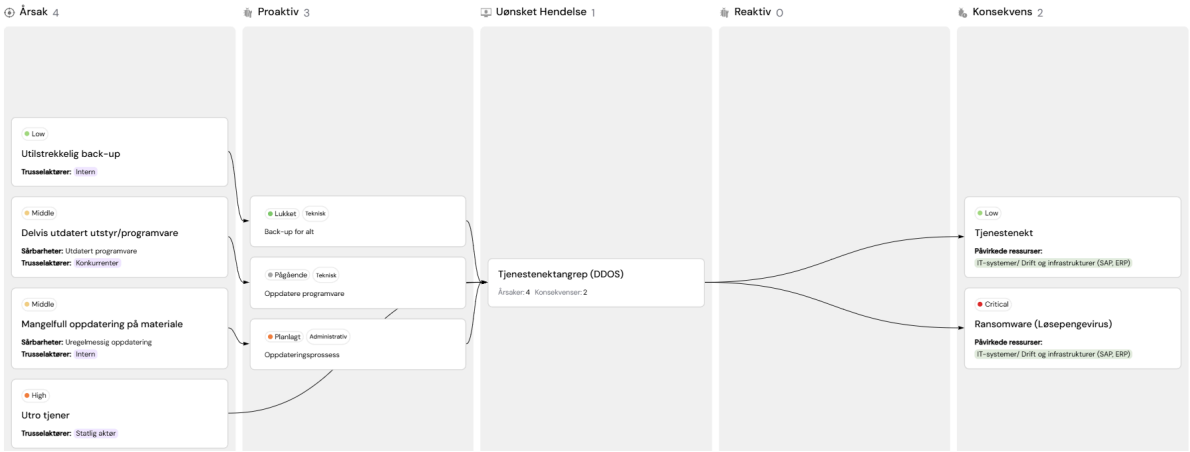
Low Middle High Critical

Sårbarhetsanalysen er gjennomført ved bruk av bowtie-metodikken i Diri-verktøyet, som viser sammenhengen mellom hendelser, årsak og konsekvensene av disse. Diagrammet visualiserer at en hendelse kan ha mange ulike årsaker og konsekvenser.





Tjenestenektangrep (DDOS)



Kapittel 10: Tiltaksanbefaling og beredskapsplan

Cybersikkerhet er blitt en sentral faktor i dagens teknologiske samfunn. For Advanced MedTech, som er en leverandør av medisinsk utstyr til det nordiske markedet, er det avgjørende å sikre både kontinuitet og troverdighet. Med kritiske teknologier som MR-maskiner og monitoreringsutstyr står selskapet i en sårbar posisjon. Et vellykket cyberangrep kan ikke bare påvirke vår egen drift, men også kompromittere pasientsikkerheten og vår posisjon som en pålitelig leverandør i helsevesenet. Dette forsterker behovet for en gjennomarbeidet cybersikkerhetsstrategi.

Denne rapporten kartlegger det eksisterende risikobildet for Advanced MedTech, inkludert risikoanalyse og vurdering av Business Impact Analysis (BIA) for å forstå hvilke trusler som kan få alvorlige konsekvenser for driften. I tillegg presenteres en tiltaksplan med anbefalinger for sikkerhetstiltak og beredskap. Målet er å sikre at vi er rustet til å møte cybertrusler og opprettholde en trygg og kontinuerlig drift.

Risikobilde

Som leverandør av medisinsk utstyr til helsevesenet, står vi i Advanced MedTech overfor betydelige cybersikkerhetstrusler som kan få alvorlige konsekvenser for både oss og våres kundene. De viktigste truslene er identifisert, som følger:

1. **Ransomware-angrep**: Har høy kapasitet og hyppighet, og kan lamme systemer og forstyrre forsyningskjeden. Et vellykket ransomware-angrep kan føre til omfattende nedetid, tap av data, samt skade på omdømme og økonomi.
2. **Datatyveri**: Et brudd på GDPR og lekkasje av sensitive opplysninger kan medføre store økonomiske og juridiske konsekvenser. Dette truer vår tillit til markedet og kan føre til høye bøter og rettslige krav.

3. **Insider-trusler**: Personell med innsidekunnskap som misbruker sin tilgang, enten med vilje eller ved uhell, kan forårsake lekkasje av interne data eller sabotere systemer. Denne risikoen er vanskelig å forutse og krever god tilgangskontroll og jevnlige revisjoner.
4. **Tjenestenektangrep (DDoS)**: En svært hyppig trussel som kan føre til midlertidig nedetid og redusert tilgjengelighet for kunder. Selv om slike angrep sjelden fører til permanente skader, kan de svekke selskapets omdømme og kundetillit.
5. **Phishing-angrep**: Hyppige angrep som utnytter menneskelige sårbarheter, der angripere lurer ansatte til å gi fra seg sensitiv informasjon. Dette kan åpne dører for andre trusler, som for eksempel ransomware.

Tabelloppsummering

Trussel	**Kapasitet**	**Kapabilitet**	**Hyppighet**	**Alvorlighet (Rangering)**	**Konsekvens**
Ransomwareangrep	Høy	Moderat til høy	Høy	1	Nedetid, tap av både omdømme og verdi
Datatyveri	Høy	Høy	Moderat	2	Brudd på GDPR, tap av verdi og juridiske problemer
Insider trusler	Moderat til høy	Moderat	Moderat	3	Sabotasje og/eller lekkasje av interne systemer
Tjenestenektangrep (DDoS)	Moderat	Lav til moderat	Høy	4	Nedetid og omdømmeskade
Phishing-angrep	Moderat	Lav	Høy	5	Potensiell lekkasje av sensitive data

(Fig. 12. Tabelloppsummering av risiko med konsekvens)

Risikomatrise: Heatmap

Sannsynlighet -> Konsekvens	Lav	Moderat	Høy
Lav			
Moderat		DDoS	Phishing
Kritisk		Insider-trusler	Datatyveri og ransomware

(Fig 13. Visuell fremstilling av risiko og konsekvens)

I lys av dette risikobildet er det tydelig at vi i Advanced MedTech må prioritere tiltak mot ransomware, datatyveri og insider-trusler, samt være forberedt på DDoS- og phishing-angrep.

Business Impact Analysis (BIA)

Gjennom en Business Impact Analysis (BIA) har vi kartlagt hvordan disse cybersikkerhetstruslene påvirker både driften og de økonomiske konsekvensene for oss.

- **Ransomware**: Som den mest alvorlige trusselen har ransomware et betydelig potensial til å skade virksomheten. Et vellykket ransomware-angrep kan sette hele ordresystemet ut av drift, noe som vil påvirke vår evne til å levere essensielt utstyr til sykehus og klinikker. Konsekvensene inkluderer økonomiske tap, omdømmeskade, tap av kundetillit og kostnader knyttet til gjenoppretting.
- **Datatyveri**: Et databrudd kan få alvorlige konsekvenser for vårt omdømme og pålitelighet i helsesektoren. GDPR-brudd kan føre til juridiske problemer og bøter, samtidig som lekkasje av sensitiv informasjon svekker kundetilliten.
- **Insider-trusler**: Selv om disse truslene ikke er like hyppige, kan de føre til omfattende konsekvenser dersom noen med innsidekunnskap misbruker sin tilgang. Dette kan omfatte sabotasje, lekkasje av konfidensiell informasjon og tap av omdømme.
- **DDoS og phishing**: Disse angrepene kan forårsake kortvarig nedetid og lekkasje av sensitiv informasjon. Selv om effektene vanligvis er midlertidige, kan de føre til svekket kundetillit og økt kostnad for gjenoppretting.

BIA viser at ransomware og datatyveri utgjør de største risikoene for økonomi og drift. Investering i en solid sikkerhetsstrategi vil derfor være avgjørende for å opprettholde kontinuitet og beskytte sensitiv informasjon.

Definer Farer og Ulykkeshendelser (DFU)

En DFU-analyse (Definer Farer og Ulykkeshendelser) identifiserer kritiske trusler og scenarier som kan ha alvorlige konsekvenser. Her tar vi utgangspunkt i ransomware, som vurderes som den største trusselen.

Ransomware kan låse tilgang til systemene våre, samt å kreve løsepenger for å frigjøre data. Dette kan komme inn gjennom phishing eller uoppdaterte systemer. Ved et vellykket angrep kan vi miste tilgang til kritiske data og funksjoner, noe som kan påvirke leveranser til våre kunder.

Tiltak for å håndtere hendelsen:

- **Isolering av infiserte systemer**: Rask isolering av infiserte systemer kan forhindre spredning og redusere skadeomfanget.
- **Gjenoppretting fra backup**: En solid backup-strategi med offline-backup som er beskyttet mot angripere, gjør at vi kan gjenopprette systemene uten å betale løsepenger.
- **Varsling av nøkkelpersonell**: Kritiske avdelinger informeres umiddelbart for rask handling gjennom en beredskapsgruppe og koordinert kommunikasjon med kunder.
- **Langsiktig beskyttelse og oppdateringer**: Systemer må kontinuerlig oppdateres for å eliminere sårbarheter og styrke sikkerhetsarkitekturen.
- **Ansattopplæring**: Regelmessig opplæring av ansatte innenfor cybersikkerhet bidrar til å redusere risikoen for phishing og andre menneskelige feil som kan resultere i angrep.

Anbefalte Sikkerhetstiltak:

Basert på risikovurderingen og DFU-analysen foreslås følgende sikkerhetstiltak for å styrke Advanced MedTechs motstandskraft mot cybertrusler:

1. Backup-strategi og gjenoppretting: En kombinert løsning av daglig online-backup og offline-backup lagret eksternt vil sikre rask gjenoppretting uten å måtte gi etter for løsepengekrav. Dette beskytter selskapets data og kundetillit under kritiske hendelser.
2. Intrusion Detection and Prevention System (IDPS): IDPS overvåker nettverkstrafikken og kan identifisere mistenkelig aktivitet tidlig. Dette kan redusere sannsynligheten for ransomware, datatyveri og phishing-angrep ved å blokkere mistenkelig aktivitet automatisk.
3. Tilgangskontroll og flerfaktorautentisering (MFA): Strenge tilgangskontroller og MFA begrenser tilgangen til sensitive systemer. Dette reduserer risikoen for insider-trusler og beskytter mot uautorisert tilgang.
4. Regelmessig sikkerhetsopplæring for ansatte: Siden menneskelige feil ofte er inngangsporten for cyberangrep, kan ansatte som kjenner til risikoene og vet hvordan de skal handle, bidra til å beskytte selskapet mot både eksterne og interne trusler.
5. Sikkerhetsoppdateringer og vedlikehold: Oppdatering av systemer eliminerer sårbarheter og reduserer risikoen for angrep. Dette tiltaket beskytter spesielt mot ransomware og andre trusler som utnytter sårbare systemer.

6. Fysisk sikkerhet og tilgangskontroll til kritiske servere: Begrenset adgang til serverrom og MFA for kritiske systemer hindrer insider-trusler og beskytter mot fysisk sabotasje.
7. Varslingssystem og krisehåndteringsplan: Et pålitelig varslingssystem gir ledelsen og IT-avdelingen beskjed om hendelser i sanntid. En oppdatert krisehåndteringsplan gjør at nøkkelpersonell kan handle raskt og strukturert ved et angrep.

Disse tiltakene vil redusere risikoen for alvorlige cyberangrep, opprettholde driftssikkerhet og beskytte sensitive opplysninger.

Beredskapsplan:

Beredskapsplanen vår sikrer rask respons og kontinuitet ved cyberhendelser, med klare ansvarsfordelinger og prosedyrer for krisehåndtering.

Essensielle avdelinger og nøkkelpersonell: IT-avdelingen og sikkerhetsspesialister er ansvarlige for å håndtere teknisk respons, inkludert isolering av infiserte systemer og gjenoppretting av data. Rask isolering og god kommunikasjon reduserer spredning av ransomware og andre trusler.

Redundans og backup: Kritiske systemer er beskyttet med redundans, som sikrer at vi kan gjenopprette data uten å betale løsepenger og opprettholde kjernefunksjoner under et angrep.

Varslingsprotokoller: Etablerte kommunikasjonsprotokoller bidrar til kontrollert informasjonsflyt, både internt og eksternt, for å opprettholde kundetillit under en krise.

Øvelser og simuleringer: Regelmessige øvelser og simuleringer av scenarier for ransomware og tjenestenektangrep gjør ansatte trygge på prosedyrene og reduserer responstid.

Evaluering og oppdatering: Beredskapsplanen evalueres jevnlig og oppdateres for å tilpasses nye trusselbilder, noe som gjør oss bedre rustet mot fremtidige angrep.

Samlet sett fremlegger denne planen et robust forsvar mot cybertrusler for oss i Advanced MedTech, samtidig som den sikrer kontinuitet og beskyttelse av omdømmet. Ved å investere i cybersikkerhet og beredskap står vi bedre rustet til å møte fremtidens utfordringer og opprettholde vår posisjon som en trygg og pålitelig leverandør i helsesektoren.

Oppsummering og anbefalinger:

For å opprettholde vår posisjon som en pålitelig leverandør i helsesektoren må vi styrke cybersikkerhetsstrategien. Gjennom risikovurderingen er det identifisert fem sentrale trusler som krever umiddelbare tiltak: ransomware-angrep, datatyveri, insider-trusler, DDoS-angrep og phishing. Ransomware og datatyveri er de mest alvorlige truslene, da de kan føre til omfattende nedetid, økonomiske tap, og skade på selskapets omdømme.

For å adressere disse risikoene anbefales følgende tiltak:

1. Implementere en solid backup-strategi, inkludert offline-backup, for å sikre rask gjenoppretting uten løsepengekrav ved ransomware-angrep.
2. Installere Intrusion Detection and Prevention Systems (IDPS) for å oppdage og blokkere mistenkelige aktiviteter i sanntid.
3. Innføre strenge tilgangskontroller og flerfaktorautentisering for å redusere risikoen for insider-trusler og uautorisert tilgang til sensitive data.
4. Gjennomføre regelmessig opplæring for ansatte for å øke bevisstheten rundt phishing og andre angrep basert på menneskelige feil.
5. Oppdatere systemer og programvare kontinuerlig for å eliminere kjente sårbarheter og redusere sannsynligheten for angrep.

En veldefinert beredskapsplan med tydelige definerte roller, ansvarsområder og enkle kommunikasjonsprotokoller vil sikre rask respons under en hendelse. Ved å gjennomføre disse tiltakene og investere i nødvendig sikkerhetsinfrastruktur, kan vi styrke evnen til å møte trusselbildet og fortsette å være en trygg og pålitelig aktør i markedet.

Referanseliste:

Nasjonal Sikkerhetsmyndighet (2024). *NSMs grunnprinsipper for IKT-sikkerhet.* NSMs Grunnprinsipper for IKT-sikkerhet v2.1.pdf Lastet ned: 31 okt. 2024, kl. 22:40

Helse Midt-Norge, Helse Nord, Helse Sør-Øst, Helse Vest, Norsk Helsenett. (2024). *Trusselvurdering 2024. Det digitale trusselbildet mot spesialisthelsetjenesten.* Trusselvurdering 2024 for spesialisthelsetjenesten - Sykehuspartner HF Lastet ned: 31 okt. 2024, kl. 22:40

Wikipedia contributors. (2024). *ISO 13485.* https://en.wikipedia.org/wiki/ISO_13485 Lastet ned: 31.okt.2024 kl: 23:00

SAP. *A to Z Product Listing of SAP Applications, Software and Platforms. (n.d.).* https://www.sap.com/products/a-z.html Lastet ned 31.okt.2024, kl 21:00

Deloitte AS. (2023, 4. August). *NIS2-direktivet: Hva er det og hvem gjelder det for?:* https://www2.deloitte.com/no/no/innsikt/teknologi/cyber/nis2-direktivet.html Lastet ned 31.okt.2024, kl 21:00

General Data Protection Regulation. (2016, 27. April). *REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL.* European Union. https://eur-lex.europa.eu/eli/reg/2016/679/oj Lastet ned 31.okt.2024, kl 21:00

ISO. (2022, oktober). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements.* ISO. https://www.iso.org/standard/27001 Lastet ned 31.okt.2024, kl 21:00

Staff, C. (2023). *What Is the CIA Triad?.* Coursera. https://www.coursera.org/articles/cia-triad Lastet ned 31.okt.2024, kl 21:00

Hvordan definerer vi risikonivået? (n.d.). https://arbinn.nho.no/hms/risikovurdering_og_avvik/risikostyring-og-avvikshandtering/qa-avvik-og-risiko-ny/hvordan-definerer-vi-risikonivaet/ Lastet ned 31.okt.2024, kl 21:00

BDO.*The healthcare cybersecurity landscape in 2024* (2024). https://www.bdo.com/insights/industries/healthcare/healthcare-security-in-2024-the-cyberthreat-landscape Lastet ned 31.okt.2024, kl 21:00

Store Norske Leksikon.(2023) *forsiktighetsprinsippet*. https://snl.no/forsiktighetsprinsippet Lastet ned 31.okt.2024, kl 21:00

Kolseth, H. I. M & Kringstad, K (2018). *Hacket til seg alle pasientopplysningene til flere hundre tusen norske pasienter.* *https://www.nrk.no/trondelag/riksrevisjonen-hacket-helseregionene_-fikk-pasientopplysninger-til-flere-hundre-tusen-pasienter-1.15294490* Lastet ned 31.okt.2024, kl 21:00

Kunnskapsbasen - NTNU. (n.d.). *Klassifisering av informasjonsverdier - retningslinje -NTNU.* https://i.ntnu.no/wiki/-/wiki/Norsk/Informasjonsklassifisering+-+informasjonssikkerhet Lastet ned: 31.okt.2024 , kl 22:00